

Threat report for Intelligent IoT data Management.

1. Executive Summary

This report presents a threat modelling for Databytes - Internet of Things (IoT) data management platform that collects sensor data from multiple IoT devices and transmits it to a backend infrastructure for storage, monitoring, analytics, and user access. It looks at possible security gaps, risk impacts, vulnerabilities and mitigation techniques. The STRIDE threat modelling framework is utilised to represent the findings.

This report analyses conducted threat modelling for potential risks including the physical layer, application layer, transport layer, internet layer and network access layer.

The specific variables include:

- IoT sensors and edge devices
- Communication networks
- APIs and backend services
- Databases and cloud infrastructure
- Authentication and access control systems
- Monitoring and logging components

2. System Overview

2.1 System Description

The IoT platform collects telemetry and environmental data from distributed sensors such as temperature sensors, humidity sensors, air quality monitors etc. The data is transmitted through APIs or MQTT/HTTP protocols to a backend server where it is authenticated, processed, stored and then Visualized through dashboards and retrieved by users or administrators

3. System Architecture

3.1 concerns

The following components take priority in addressing security concerns:

Physical device protection from environmental events, sensor data from tampering, role based access control, token authorisation, device identities for spoofing and database security.

3.2 Threat modelling table:

TCP/IP Layer	Asset	STRIDE Threat Category	Example Threat
Physical	Physical sensor devices	Denial of Service (DoS)	Environmental events such as intense heat, water damage, dust, insects or power surges causing device failure or service disruption
Application	Sensor telemetry data	Tampering	Modification of sensor readings before storage
Application	REST APIs / MQTT APIs	DoS	API flooding causing service outage
Application	JWT authentication tokens	Spoofing	Stolen or forged JWT token used for impersonation
Application	User accounts and RBAC roles	Elevation of Privilege	User gains unauthorised admin access
Application	Audit logs	Repudiation	User denies performing malicious actions
Store JWT tokens in HTTP-only cookies	Application Layer	Information Disclosure / Spoofing	Reduces JavaScript access to tokens and lowers risk of token theft through XSS attacks
Pass JWT token during WebSocket connection	Application Layer	Spoofing	Authenticates users/devices before allowing socket communication
Rate limiting and WebSocket authentication	Application Layer	Denial of Service / Spoofing	Prevents connection flooding and unauthorized socket access
Secure database system	Application Layer	Tampering / Information Disclosure	Protects stored telemetry and user account data from unauthorized access or modification
Store passwords and secrets in <code>.env</code> file and exclude using <code>.gitignore</code>	Application Layer	Information Disclosure	Prevents accidental exposure of credentials in source code repositories

Input validation and parameterized SQL queries for login/register forms	Application Layer	Tampering / Elevation of Privilege	Prevents SQL injection attacks that could manipulate database queries, bypass authentication, or access unauthorised data
Internet	Device IP addresses	Information Disclosure	Network reconnaissance exposing device locations
Network Access	IoT devices and sensors	Spoofing	Rogue device pretending to be legitimate
Network Access	Wi-Fi / LAN infrastructure	Information Disclosure	Unauthorised access to local wireless traffic
Network Access	Physical communication channels	Tampering	Physical interception of network traffic
Network Access	Switches and gateways	Dos	Network flooding attacks overwhelming gateways
Network Access	Device firmware and MAC addresses	Elevation of Privilege	Compromised firmware granting unauthorised control

4. STRIDE Threat Analysis

4.1 Spoofing Identity

Threats associated with potential spoofing attacks include:

- Fake IoT devices sending malicious data
- JWT token theft
- Credential stuffing attacks
- Session hijacking

These threats can create risks such as unauthorised access into the database. This can further cause unauthorised data injection, compromise user accounts with admin privileges and lead to device impersonation of sensors. The existing security controls such as RBAC, JWT, and bcrypt hashing provide a good foundation to tackle these.

Extending these services include adding:

- Multi-factor authentication (MFA)
- Device certificates
- Token expiration and rotation
- Rate limiting on login APIs

4.2 Tampering

Threats associated with potential device tampering include:

- Modification of sensor data during transmission
- API request manipulation
- Database alteration
- Firmware tampering

Tampering can create fake anomalies within the data, giving false readings and having a draw back effect on the project. False data can lead to incorrect analysis and ruin the data integrity. Further, this impacts how the project operates as decisions can change based on sensor readings.

Recommended Mitigations

- HTTPS/TLS encryption
- Message signing
- Integrity validation
- Secure firmware updates
- Input validation and sanitisation

4.3 Repudiation

Threats

- Users denying actions
- Devices denying transmissions
- Log deletion

Repuditions can occur with lack of audit trails where attackers can deny services. The lack of documentation can make it difficult to trace actions for forensic investigations. This can impact overall system health.

Recommended Mitigations

- Centralised logging
- Immutable audit logs
- Timestamped event tracking
- Device transaction identifiers

4.4 Information Disclosure

Threats

- Data leakage through APIs
- Weak access controls
- Exposed cloud storage
- Packet sniffing
- Insecure debug endpoints

Privacy and sensitive data should be checked and be secured within the program. This includes looking at user roles and ensuring those with escalated privileges don't have any data leaks occurring. This consists of the sensor data, user credentials and ensuring they meet the privacy regulations of the region.

Recommended Mitigations:

- TLS encryption
- RBAC enforcement
- API authentication
- Secure secret management
- Encryption at rest
- Disable unnecessary debug endpoints

4.5 Denial of Service (DoS)

Threats:

- API flooding
- MQTT broker overload
- Resource exhaustion
- Botnet attacks

DoS is another concern that looks at multiple components of the project. Many of the threats can be addressed through rate limiting to prevent service exhaustion. These threats can lead to system outages and adversaries can use this to gain access to sensitive data. Additionally, this leads to service degradation the more the system is subject to DoS.

Recommended Mitigations:

- Rate limiting
- Load balancing
- Auto-scaling infrastructure
- DDoS protection services
- Request throttling
- Queue buffering

4.6 Elevation of Privilege

Threats

- RBAC bypass
- Broken authorization logic
- Privilege escalation through APIs
- Insecure admin routes

The user roles in place currently are for test user, user and admin. The admin routes should be protected and appropriate privileges should be in place for all users. Interlapping privileges can lead to a compromised system, even if admin controls are separated. There should be a separation for higher level privileges and not all should be available for all user groups. Doing so reduces adversaries from compromising the system and prevents administrative access.

Recommended Mitigations

- Strict RBAC enforcement
- Principle of least privilege
- Authorization middleware
- Security testing of privileged endpoints
- Reduce number of admin users

- Revalidate admin users regularly

4.7 Physical Device Tampering

Risks

- Device theft
- Sensor manipulation
- Sensor damage and false readings

Sensors should be considered for environmental damage depending on where they're placed. This could be insects, wind damage etc. Additionally, they should be checked on a regular basis with adequate audit reporting for documentation purposes. By checking, it prevents false data readings occurring from faulty sensors which can negatively impact the project.

Mitigations

- Tamper-resistant casing
- Physical access monitoring
- Secure hardware modules
- Regular monitoring

4.8. Weak Device Security

Risks

- Hardcoded credentials
- Default passwords
- Outdated firmware

Weak device security includes using default passwords for user groups such as 'user123, or admin'. Passwords should follow secure passphrase designs such as adding symbols, letters, and numbers. Firmware and sensor devices should be updated too. Secure boot mechanisms will validate the sensors' firmware using secure keys (which exists during the initial manufacturing). This prevents illegitimate devices in the system being used by adversaries.

Mitigations

- Enforce password changes, no default passwords
- Secure boot mechanisms
- Signed firmware updates

Risk Matrix for likely attacks:

Threat	Likelihood	Impact	Risk Level
JWT token theft	Medium	High	High
Device spoofing	High	High	Critical
API DoS attack	High	Medium	High
Data tampering	Medium	High	High
Weak RBAC	Medium	Critical	Critical
Firmware compromise	Low	Critical	High
Log manipulation	Medium	Medium	Medium

Recommended Security Improvements:

Implement Device Authentication: This includes using unique identifiers for sensors, and device certificates.

Secure API Gateway: By utilising rate limiting, API monitoring, Web Application Firewall

Improve Logging: Centralised logging system, audit trails, security alerts

Encrypt Sensitive Data: TLS in transit, AES encryption at rest

Network Segmentation: Ensure the , IoT network Admin system and database infrastructure

Conclusion

In conclusion, Intelligent IoT data management encompasses various components that require security concerns to be addressed as the project moves forward. The data platform faces multiple concerns including large attack surfaces, distributed devices, internet exposure and sensitive telemetry handling. The STRIDE model maps the concerns into its respectable categories. The current security factors include the authentication service which consists of JWT, RBAC, and bcrypt password security. The security needs to be extended to sensor authentication, data integrity, API security, enhanced logging/monitoring of sensors, and DoS prevention. This in turn helps the project follow secure practises to improve the integrity of data, reduce high level access and have confidentiality.

References:

- [1]
L. Conklin, "Threat Modeling Process | OWASP," *owasp.org*, 2022.
https://owasp.org/www-community/Threat_Modeling_Process
- [2]
K. Sood, M. R. Nosouhi, N. Kumar, A. Gaddam, B. Feng, and S. Yu, "Accurate Detection of IoT Sensor Behaviors in Legitimate, Faulty and Compromised Scenarios," *IEEE Transactions on Dependable and Secure Computing*, pp. 1–1, 2021, doi: <https://doi.org/10.1109/tdsc.2021.3131991>.
- [3]
K. Sood, S. Yu, D. D. N. Nguyen, Y. Xiang, B. Feng, and X. Zhang, "A Tutorial on Next Generation Heterogeneous IoT Networks and Node Authentication," *IEEE Internet of Things Magazine*, vol. 4, no. 4, pp. 120–126, Dec. 2021, doi: <https://doi.org/10.1109/iotm.001.2100115>.
- [4]
A. Seeam, O. S. Ogbah, S. Guness, and X. Bellekens, "Threat Modeling and Security Issues for the Internet of Things," *IEEE Xplore*, Sep. 01, 2019. <https://ieeexplore.ieee.org/document/8883642> (accessed Apr. 06, 2021).